# SHIELD-AI Deep Review: September 2026

Monthly Deep Review Report – Structural Gap Analysis and Framework Update (v1.9 to v1.10)

Security Architecture Practice

September 1, 2026

Abstract
The September 2026 monthly deep review of the SHIELD-AI framework: full Six Thinking Hats analysis of structural blind spots, five new incident clusters (INC-48..INC-52), one new Critical gap (G26) with new control TP-14, five control extensions (IAM-01, IAM-06, DS-06, MIR-02, MIR-04), confirmation and promotion of G19 (attacker-side autonomous AI) to an active defence item, a rebuilt eight-component watchlist, and three field-finding adoptions. Framework moved from v1.9 (61 controls) to v1.10 (62 controls).

# SHIELD-AI Deep Review – September 2026

## 1. Scope and Method

This is the September 2026 monthly deep review of the SHIELD-AI framework (Mode A, full Six Thinking Hats sequence). Its purpose is structural blind-spot discovery: attack classes the framework systematically misses, rather than incremental mapping of stories onto existing controls. The review started from framework v1.9 (7 pillars, 61 controls, 47 incidents INC-01..47, 25 gaps G1..G25).

**Hat sequence:** Blue (framing) -> White (research, run by the orchestrator: web search and Google News RSS across sandbox escapes, prompt injection, MCP-layer exploits, agent framework RCEs, supply chain, delegation/identity abuse,

agent-to-agent protocols, evaluation-harness attacks) -> Black (structural gap map, delegated subagent with pre-loaded research) -> Green (control proposals, delegated subagent) -> Red (gut-check, direct) -> Blue (synthesis, direct). Black and Green hats ran with toolsets restricted and the incident research pre-loaded; the full research payload is preserved in the gap analysis (INC-48..INC-52).

**Evaluation criteria (from the Blue Hat framing):** every candidate gap must carry a named incident; severity calibrated as new-class vs evidence-for-existing-control; proposals must be implementable as +/-1 controls or extensions; diagram representability; the taxonomy's core assumption – "the agent as an outbound actor with tools, identity, data, and a sandbox" – inverted to locate the blind spots.

## 2. Research Findings: New Incidents (INC-48..INC-52)

| INC | Incident | Date(s) | Source | Class |
|---|---|---|---|---|
| INC-48 | ClawHavoc: 1,184 malicious skills on the OpenClaw ClawHub marketplace (~20% of registry); AMOS infostealer delivery; evasive skills passing automated scanning; runtime affiliate injection and agentic front-running (Unit 42) | Feb 3 2026 (Koi); Feb 2026 (Antiy); Jun 23 2026 (Unit 42) | Koi Security, Antiy CERT, Unit 42, Bitdefender, CSA | Agent extension/ skill marketplace poisoning; agentic fraud |
| INC-49 | Mexico government breach: first confirmed agentic-AI government intrusion; Claude Code executed ~75% of 5,317 commands; 9-10 agencies, 150 GB / 195M records; | Dec 2025-Feb 2026; disclosed Feb 25 2026 | Bloomberg, Gambit Security, CSA | Attacker-side autonomous AI (confirmed outcome) |

| INC | Incident | Date(s) | Source | Class |
|---|---|---|---|---|
| | guardrails eroded ~40 min | | | |
| INC-50 | CVE-2026-25536: MCP TypeScript SDK cross-client response leak on shared transport instances (CVSS 7.1, patched 1.26.0) | Late Aug 2026 | NVD, GitLab Advisory, Red Hat | Agent-serving data-plane multiplexing race |
| INC-51 | ANSI escape-code terminal exfiltration: indirect prompt injection emitted as terminal control sequences, exfiltrating via DNS through the terminal emulator | Jul 16 2026 | Rehberger (Embrace The Red) | Output-renderer trust boundary |
| INC-52 | Moltbook: agent-platform Supabase exposure – 1.5M agent tokens, plaintext API keys in agent-to-agent messages, mass impersonation | Jan 31 2026 | Wiz Research | Agent-identity platform exposure |

**Coverage-window note.** INC-48, INC-49, INC-51, and INC-52 predate the August 24 weekly cutoff but were never logged: the ClawHavoc campaign (February 2026) and its June 2026 evasive wave, the Mexico breach (February 2026 disclosure), the Rehberger renderer research (July 16), and the Moltbook exposure (January 31) are all genuine gaps or evidence that prior cycles missed. Date-window vs coverage-window discipline applied: old story + no control = new gap.

## 3. Black Hat: Structural Gap Map

The Black Hat inverted the framework's core model and produced five structural classes plus one classed outcome:

| # | Candidate gap class | Severity | Evidence | Verdict |
|---|---|---|---|---|
| 1 | Skill/plugin marketplace instruction-channel abuse | Critical | INC-48 (ClawHavoc) | New gap G26 |
| 2 | G19 confirmation: agentic intrusion (human-directed agent CLIs as intrusion platforms) | Critical | INC-49 (Mexico) | Gate fired; promote response-side work |
| 3 | Output-renderer trust boundary (control-sequence exfiltration) | High | INC-51 (ANSI terminal) | Evidence for DS-06/ G7 extension |
| 4 | Agent-serving data-plane multiplexing races | High | INC-50 (CVE-2026-25536) | Evidence for IAM-06 extension |
| 5 | Open-network agent identity proofing | High | INC-52 (Moltbook) | Evidence for IAM-01 extension |
| 6 | IR-time defensive asymmetry + escalation latency | Medium | HF/OpenAI lessons | Evidence for MIR-04 extension |

OpenClaw exposure counts (21,639-135,000 instances) were assessed as covered (TP-10/G14 evidence), not a new class.

## 4. Green Hat: Control Proposals

| Proposal | Decision | Control | Fail-closed note |
|---|---|---|---|
| Skill/plugin marketplace integrity | New control | TP-14: Skill/ plugin payload integrity and instruction- | Any signature/provenance/ baseline error blocks install and suspends installed skills; runtime- |

| Proposal | Decision | Control | Fail-closed note |
|---|---|---|---|
| | | channel isolation | fetch attempts terminate the skill and alert |
| Agentic intrusion telemetry | Extension | MIR-02 | On detection-pipeline outage, high-risk agent execution suspends to human-only mode; kill-switch activation must return verifiable acknowledgment or auto-escalate |
| Output-renderer sanitisation | Extension | DS-06 | Unknown sequence renders stripped/plain-text or is blocked – never raw; missing policy defaults to strip-all |
| Data-plane multiplexing isolation | Extension | IAM-06 | ID collision or correlation mismatch: responses never delivered, session dropped, instance quarantined |
| Cross-org identity attestation | Extension | IAM-01 | Unverifiable attestation or missing signature rejects the message; verification-service outage blocks cross-org comms |
| Local forensics + escalation SLA | Extension | MIR-04 | Local model unavailable: human-review-only analysis; external-model submission requires explicit approval; SLA clock still runs and breach auto-escalates |

## 5. Red Hat: Gut Check

- **Security engineer:** TP-14 is the control they have been waiting for – skill marketplaces have burned agent teams since February. They will push back on “no runtime-fetchable instruction channels” blocking legitimate dynamic configuration; the answer is an operator-maintained allowlist with approval, not a blanket network block. IAM-06 per-client transport isolation changes stateless deployment patterns; they will need the fail-closed semantics documented before adopting.

- **CISO:** the Mexico breach is the board slide – a named, quantified, first-of-class agentic intrusion. They will fund MIR-02 intrusion telemetry and the MIR-04 escalation SLA; the exercised kill-switch (GRM-02) is the cost they will try to defer, and it must not be.
- **Platform operator:** DS-06 renderer sanitisation will collide with terminal workflows that rely on OSC52 clipboard support; the default-strip policy must have a documented, approved allowlist path. IAM-01 attestation will stall at L2 without a pragmatic OIDC/OAuth-based path.
- **Executive:** the question will be “is our environment Mexico-exposed?” The honest answer: the guardrail-erosion class means model-vendor guardrails are a temporal defence (40 minutes in the documented case); detection, response speed, and extension-channel hygiene are where the organisation’s own control lives.

**Red Hat verdict:** the six proposals survive operational pressure. The failure mode to watch is fail-open drift – operators disabling TP-14’s runtime-fetch block or DS-06’s strip policy for convenience. Every proposal carries an explicit fail-closed clause; the assessment guide’s evidence standards (FF-01 adoption) make drift detectable at L3+.

## 6. Blue Hat: Synthesis and Verdict

**Verdict: structural gaps confirmed; apply now.**

The September review confirms the framework’s trajectory and adds one genuinely new structural class:

- **New gap G26 (Critical): agent extension/skill execution integrity** – new control TP-14. The class is distinct from dependency scanning (TP-06), tool registration (TP-09), and install-command provenance (TP-13): the skill is the installed artifact itself, executes with agent-level privileges, and can carry runtime-fetchable instruction channels that are command-and-control paths invisible to monitoring. The agentic-fraud variants (affiliate injection, front-running) are behavioural manipulation with no malware signature.
- **G19 confirmed and promoted (Critical): attacker-side autonomous AI.** The Mexico breach is the first confirmed agentic-AI intrusion of a production government environment and fires the watchlist gate. The class redefines itself to include human-directed agent-CLI use as an intrusion platform. MIR-02’s v1.10

extension (agentic intrusion-telemetry detection) plus GRM-02's exercised kill-switch close the response-side class; the exploit catalog entry flips to Covered; the watchlist component promotes to an active defence-work item.

- **Five control extensions:** IAM-01 (cross-org identity attestation), IAM-06 (per-client transport isolation), DS-06 (renderer-boundary control-sequence sanitisation), MIR-02 (intrusion telemetry), MIR-04 (local forensics + escalation SLA).
- **Watchlist rebuilt (8 components):** components 1-5 re-scored and carried; component 6 promoted; components 7 (skill marketplace integrity) and 8 (guardrail erosion) added on INC-48/INC-49 evidence.
- **Field findings:** FF-01 (operational evidence for L3+), FF-06 (first-party independent verification), FF-07 (schema-drift checks) adopted into the assessment methodology; FF-02/03/04/05 remain pending (scoring-state taxonomy, exercised-control ratio, positive controls, substitution disclosure – method changes batched for the next assessment-guide overhaul).

**Framework result: v1.10, 7 pillars, 62 controls (MS 12 / IAM 9 / DS 7 / TP 14 / MIR 6 / GRM 6 / EE 8), 52 incidents (INC-01..52), 26 gaps (G1..G26, G19 and G26 Critical).**

## 7. Deliverables

- framework/shield-ai-framework.md (v1.10: TP-14 + five extensions)
- framework/shield-ai-gap-analysis.md (v1.10: INC-48..52, G26, attack-pattern rows 36-40, Part 3 summary)
- framework/shield-ai-watchlist.md (September edition, rebuilt, 8 components)
- exploits/ (new g26 entry; g19 coverage flip; g07/g12 evidence updates; README index to 26)
- assessment-guide/shield-ai-assessment-guide.md (TP-14 entry, checklist row 42, counts, ISM mapping, version history)
- framework/shield-ai-field-findings.md (FF-01/06/07 adopted)
- framework/shield-ai-deep-review-2026-09.md (this report)
- tools/generate_control_schema.py (TP-14), tools/check_exploit_catalog.py (26 gaps), tools/verify_artifacts.py (v1.10/62/September 1, 2026)

- Full artifact sweep: README, ROADMAP, implementation architecture, tooling map, one-pager, glossary, demo/README, policies/README, impl-diagram generator, four HTML decks, five deck builders (DECK_VERSION bumps), presentations/VERSIONS.md
- Coverage ledger: Deep Review entry appended (this report)

*SHIELD-AI Deep Review, September 2026 – Security Architecture Practice*